CRISC Domain C - 100 Very Hard Questions

Risk Response and Reporting - Expert Level

CRISC Mastery Series

October 21, 2026

Outline

1. 1. Risk Response Strategies
2. 2. Risk and Control Ownership
3. 3. Third-Party Risk Management
4. 4. Control Design and Implementation
5. 5. Monitoring and Reporting
6. 6. Advanced Traps and Scenarios
7. 7. More Advanced Questions
8. 8. Final Advanced Questions

Q1: Mitigate vs Transfer Trap

Question

An organization outsources its payroll processing to a third-party vendor. The contract includes indemnification clauses requiring the vendor to repay any financial losses caused by vendor negligence. The organization's risk manager classifies this as risk transfer. Is this correct?

A. Yes, because the contract shifts liability to the vendor

B. No, because the organization retains accountability for payroll data

C. Yes, because indemnification clauses constitute transfer

D. No, because outsourcing always constitutes avoidance

Q1: Explanation

Correct Answer: B

Outsourcing with indemnification is a combination of mitigation (reducing likelihood through vendor expertise) and partial transfer (financial indemnity). However, the organization **retains ultimate accountability** for payroll data and compliance. True transfer requires shifting both financial impact AND responsibility to another party (e.g., insurance). The reputational and regulatory accountability remains with the organization.

Critical Trap

Outsourcing = Mitigation + Partial Transfer, NOT pure Transfer. Accountability never transfers.

Q2: Cost-Benefit Decision Logic

Question

A risk has an inherent risk exposure of $500,000 annually. The cost to implement controls to reduce this exposure to $50,000 is $200,000 annually. However, the organization's risk appetite is $75,000. What is the MOST appropriate action?

A. Accept the risk because residual risk is below $500,000

B. Implement the controls because residual risk ($50,000) is below risk appetite ($75,000)

C. Transfer the risk because it exceeds risk appetite

D. Avoid the risk entirely because it exceeds risk appetite

Q2: Explanation

Correct Answer: B

The cost-benefit analysis: $200,000 control cost ¡ $450,000 risk reduction ($500,000 - $50,000). The residual risk ($50,000) falls below the risk appetite ($75,000). This is the textbook scenario where mitigation is justified both economically and strategically.

Why Others Are Wrong

- **A:** Acceptance leaves risk above appetite ($500,000 ¿ $75,000)
- **C:** Transfer may not be cost-effective if controls work
- **D:** Avoidance is extreme when controls can achieve acceptable risk

Q3: Risk Avoidance Irreversibility

Question

A company decides to shut down its e-commerce platform due to persistent DDoS attacks. The CEO argues this is risk mitigation because they are reducing the attack surface. The risk manager disagrees. Who is correct and why?

A. CEO is correct because reducing attack surface is mitigation

B. Risk manager is correct because termination of activity is avoidance

C. Both are correct - it can be classified either way

D. Neither is correct - this is risk acceptance

Q3: Explanation

Correct Answer: B

Avoidance = terminating the activity that gives rise to risk entirely. Shutting down the e-commerce platform eliminates the DDoS risk because the platform no longer exists. This is NOT mitigation (which would involve implementing DDoS protection while keeping the platform operational). Avoidance is irreversible and requires senior management approval.

Critical Trap

Shutting down a business function = Avoidance, NOT Mitigation. Mitigation = Keep the function, reduce the risk.

Q4: Transfer with Residual Reputational Risk

Question

An organization purchases cyber insurance covering $10 million in breach costs. After a breach occurs and the insurance pays out, what risk remains with the organization?

A. No risk remains because insurance covers all costs

B. Only the deductible amount remains as risk

C. Reputational damage, customer trust loss, and regulatory accountability

D. Only legal fees remain as risk

Q4: Explanation

Correct Answer: C

Insurance transfers **financial** risk but NOT reputational, strategic, or accountability risk. After a breach:

- Customers may leave (revenue loss)
- Brand reputation is damaged
- Regulators still hold the organization accountable
- Lawsuits may still name the organization

Critical Trap

Transfer = Financial only. Reputational and accountability risk ALWAYS remains.

Q5: Acceptance with Unknown Risk

Question

A business unit head accepts a risk without understanding its potential impact because "it hasn't happened yet." This is an example of:

A. Informed risk acceptance
B. Uninformed risk acceptance (negligence)
C. Risk avoidance
D. Risk transfer

Q5: Explanation

Correct Answer: B

Risk acceptance must be **informed**. Accepting risk without understanding impact is negligence and could lead to legal liability. Proper acceptance requires:

- Understanding the risk (likelihood and impact)
- Understanding the consequences of acceptance
- Formal documentation and sign-off
- Periodic review

Critical Trap

Acceptance without understanding = Negligence, NOT valid acceptance.

Q6: Mitigation Cost Exceeds Asset Value

Question

A $5,000 laptop contains sensitive data. The cost to implement full-disk encryption and endpoint protection is $8,000. What is the BEST risk response?

- A Implement the controls anyway because data is sensitive
- B Accept the risk because control cost exceeds asset value
- C Transfer the risk through insurance
- D Avoid the risk by not using laptops

Q6: Explanation

Correct Answer: B

The fundamental principle: **cost of control should not exceed the value of the asset**. Since $8,000 ¿ $5,000, the control is not economically justified. Accept the risk (with documentation) or consider lower-cost controls. However, note that if the data value exceeds the laptop value, the equation changes.

Critical Trap

Cost of control vs. Asset value is the primary decision factor. $8,000 control on $5,000 asset = Accept the risk.

Q7: Risk Response Selection with Multiple Factors

Question

A company faces a risk of $2M from a data breach. Options:

- Option A: Implement controls costing $500K, reducing risk to $200K
- Option B: Purchase insurance costing $300K, covering $1.5M
- Option C: Outsource to vendor costing $400K, transferring operational risk

The company's risk appetite is $250K. What is the BEST response?

A. Option A only
B. Option B only
C. Option C only
D. Option A and B combined

Q7: Explanation

Correct Answer: D

Option A + B Combined:

- Controls reduce risk to $200K (below appetite of $250K)
- Insurance covers remaining $200K financial exposure
- Total cost: $800K for $2M risk reduction = strong ROI
- Residual risk after both: $0 financial, but reputational risk remains

Why Not Others

- A alone: Residual $200K is below appetite but still significant
- B alone: Doesn't reduce likelihood, only financial impact
- C alone: Doesn't address the core risk, only shifts operations

Q8: Avoidance vs. Acceptance Trap

Question

A company decides not to pursue a new market because the regulatory risk is too high. This is:

A. Risk acceptance because they are accepting the opportunity cost
B. Risk avoidance because they are not entering the market
C. Risk mitigation because they are reducing exposure
D. Risk transfer because they are shifting risk to competitors

Q8: Explanation

Correct Answer: B

Avoidance = Not engaging in the activity that creates the risk. By not entering the market, the company avoids the regulatory risk entirely. This is a valid avoidance strategy.

Critical Trap

Not doing something = Avoidance. Doing something and accepting the consequences = Acceptance.

Q9: Transfer Limitations

Question

Which risk CANNOT be effectively transferred?

A. Financial loss from a data breach
B. Regulatory accountability for data protection
C. Property damage from a natural disaster
D. Liability from a product defect

Q9: Explanation

Correct Answer: B

Regulatory accountability cannot be transferred. While you can transfer financial liability through insurance or contracts, regulators hold the **original organization** accountable for compliance. You cannot "outsource" your regulatory responsibility.

What Can Be Transferred

- Financial losses (insurance)
- Operational risk (outsourcing)
- Liability (contracts with indemnification)

Critical Trap

Regulatory accountability = Non-transferable. You can never transfer your legal responsibility to a regulator.

Q10: Mitigation vs. Compensating Controls

Question

A legacy system cannot be patched due to vendor restrictions. The security team implements network segmentation and enhanced monitoring. This is:

A. Risk avoidance because the vulnerability is eliminated
B. Risk mitigation through compensating controls
C. Risk acceptance because the system remains vulnerable
D. Risk transfer because monitoring is outsourced

Q10: Explanation

Correct Answer: B

Compensating controls are a form of mitigation. When primary controls cannot be implemented, compensating controls reduce the likelihood or impact of exploitation. Network segmentation reduces lateral movement; enhanced monitoring increases detection.

Why Not Others

- A: The vulnerability is NOT eliminated (system is still unpatched)
- C: The organization is NOT passively accepting (they implemented controls)
- D: Monitoring being outsourced doesn't make it transfer

Q11: Risk Owner vs. Control Owner Conflict

Question

The risk owner for a critical application wants to accept a high-severity vulnerability because remediation costs $500K. The control owner insists on remediation due to regulatory requirements. Who has the authority to make the final decision?

A. Risk owner, because they own the risk

B. Control owner, because they own the control

C. Senior management, because it involves regulatory risk

D. Both must agree for any decision to be made

Q11: Explanation

Correct Answer: C

Senior management must make the decision because:

- Regulatory risk affects the entire organization, not just one business unit
- Risk acceptance above risk appetite requires executive approval
- Legal/regulatory obligations override cost considerations
- Risk owner cannot unilaterally accept regulatory non-compliance

Critical Trap

Risk owner not equal to Final authority on ALL risk decisions.
Regulatory/legal risk = Senior management decision.

Q12: Multiple Risk Owners

Question

A risk affects three business units: Marketing, Sales, and Operations. Each BU head wants to be the risk owner. What is the BEST approach?

A. Appoint all three as co-owners
B. Appoint the BU with the largest budget as owner
C. Appoint a single owner with authority across all BUs
D. Escalate to the board for decision

Q12: Explanation

Correct Answer: C

Risk ownership requires **single-point accountability**. A risk owner must have:

- Authority to make decisions across all affected areas
- Budget control to implement risk responses
- Accountability for outcomes

Co-ownership dilutes accountability. The owner should be the executive with cross-functional authority (e.g., CRO, COO).

Critical Trap

Multiple owners = No owner. Single point of accountability is required.

Q13: Control Owner Without Authority

Question

A control owner identifies that a critical control is ineffective but has no budget to fix it. What should they do FIRST?

A. Document the finding and escalate to the risk owner

B. Implement a compensating control anyway

C. Accept the risk and move on

D. Wait for the next audit cycle to report

Q13: Explanation

Correct Answer: A

The control owner must **escalate to the risk owner** who has the budget authority. The control owner is responsible for the control's effectiveness but may not have budget authority. The risk owner is accountable for ensuring the risk is treated.

Why Not Others

- B: Compensating controls require risk owner approval
- C: Control owner cannot unilaterally accept risk
- D: Delaying reporting increases exposure

Q14: Risk Owner Outside IT

Question

The risk owner for a cybersecurity risk is the VP of Marketing. IT disagrees with this appointment. Who is correct?

A. IT is correct - cybersecurity risks must be owned by IT
B. VP of Marketing is correct if the risk impacts marketing objectives
C. Neither is correct - the CISO should own all cyber risks
D. The board should decide who owns the risk

Q14: Explanation

Correct Answer: B

Business risk is owned by business leaders. If a cyber risk (e.g., data breach of customer marketing data) impacts marketing objectives, the VP of Marketing is the appropriate owner. IT is an enabler, not the owner of business risk.

Critical Trap

IT does NOT own business risk. The business leader who owns the objective owns the risk.

Q15: Delegation of Risk Ownership

Question

A risk owner goes on extended leave. They delegate risk ownership to a subordinate. What must happen?

A. Nothing - delegation is automatic

B. The delegation must be documented and communicated to stakeholders

C. The risk should be transferred to another department

D. The risk should be accepted until the owner returns

Q15: Explanation

Correct Answer: B

Delegation must be **formal, documented, and communicated.** The delegate must:

- Have the authority and budget to make decisions
- Understand the risk and current status
- Be known to all stakeholders
- Have clear boundaries on what they can/cannot approve

Critical Trap

Undocumented delegation = No accountability. Always document delegations formally.

Q16: Vendor Breach Accountability

Question

A SaaS vendor suffers a breach exposing your customer data. The vendor's contract includes a $5M indemnification clause. Who is held accountable by regulators?

A. The SaaS vendor
B. Your organization
C. Both organizations equally
D. The indemnification clause shifts all accountability

Q16: Explanation

Correct Answer: B

Your organization is held accountable by regulators. You cannot outsource regulatory accountability. The indemnification clause provides **financial compensation** but does not shift legal responsibility.

Critical Trap

Regulators hold YOU accountable for vendor breaches. Indemnification = Financial only, NOT accountability.

Q17: Fourth-Party Risk

Question

Your critical SaaS vendor uses a subcontractor for data storage. The subcontractor suffers a breach. Which statement is TRUE?

A. Only the subcontractor is liable
B. Your organization has fourth-party risk exposure
C. The SaaS vendor bears all responsibility
D. Regulatory liability ends at your organization

Q17: Explanation

Correct Answer: B

Fourth-party risk = risk from your vendor's vendors. You have exposure because:

- Your data is held by the subcontractor
- Your SaaS vendor may not have adequate oversight
- Regulators still hold you accountable
- You may not have contractual privity with the subcontractor

Critical Trap

Fourth-party risk = Your vendor's vendor. You are still exposed even without a direct contract.

Q18: Vendor Assessment Timing

Question

When is the BEST time to conduct a vendor security assessment?

A. Before signing the contract
B. After the contract is signed but before go-live
C. After go-live in the first 30 days
D. Annually after go-live

Q18: Explanation

Correct Answer: A

The assessment should occur **before signing the contract** so that:

- You can negotiate security requirements into the contract
- You can make an informed decision about the vendor
- You can identify deal-breakers before commitment
- You have leverage to require improvements

Critical Trap

Assessment AFTER contract = No leverage. Assessment BEFORE contract = Negotiating power.

Q19: SOC 2 Report Limitations

Question

A vendor provides a SOC 2 Type I report. What does this NOT provide?

A. Evidence of control design at a point in time
B. Evidence of control operating effectiveness over a period
C. Evidence of management's description of controls
D. Evidence of the auditor's opinion

Q19: Explanation

Correct Answer: B

SOC 2 Type I covers control **design** at a specific point in time. **SOC 2 Type II** covers control **operating effectiveness** over a period (typically 6-12 months). Type I does NOT prove the controls operated effectively.

Critical Trap

Type I = Design only (snapshot). Type II = Design + Operating effectiveness (period).

Q20: Vendor Contract Must-Haves

Question

Which clause is MOST critical in a vendor contract for data protection?

A. Service level agreement with financial penalties
B. Right to audit and security requirements
C. Indemnification for all losses
D. Non-disclosure agreement

Q20: Explanation

Correct Answer: B

Right to audit + security requirements is most critical because:

- It provides ongoing verification of compliance
- It establishes minimum security standards
- It gives you recourse if standards are not met
- Financial penalties (A) don't prevent breaches
- Indemnification (C) doesn't prevent breaches

Critical Trap

Financial penalties don't prevent breaches. Right to audit + security requirements = Prevention.

Q21: Exception Management Duration

Question

An exception to policy is approved for a critical business function. How long can it remain open?

A. Until the next audit cycle

B. Maximum 1 year, reviewed at least annually

C. Indefinitely if the business need continues

D. Maximum 30 days

Q21: Explanation

Correct Answer: B

Exceptions should be reviewed **at least annually**. The maximum duration should be clearly defined, typically 1 year. At each review:

- Verify the business need still exists
- Assess if compensating controls are effective
- Determine if the exception can be closed
- Re-approve if necessary

Critical Trap

Exceptions are NOT permanent. Annual review = Minimum requirement.

Q22: Vendor Offboarding Risk

Question

What is the GREATEST risk during vendor offboarding?

A. Loss of service availability

B. Data remanence (data not properly destroyed)

C. Increased costs during transition

D. Loss of institutional knowledge

Q22: Explanation

Correct Answer: B

Data remanence is the greatest risk because:

- Vendor may retain copies of your data
- Data may be in backups not properly deleted
- Vendor may reuse storage without sanitization
- Regulatory violations if data is not properly destroyed
- Reputational damage if data leaks post-termination

Critical Trap

Offboarding = Data destruction is 1 priority. Certificate of destruction is required.

Q23: Preventive vs. Deterrent

Question

An organization installs signs warning of prosecution for unauthorized access. What type of control is this?

A. Preventive
B. Detective
C. Deterrent
D. Corrective

Q23: Explanation

Correct Answer: C

Deterrent controls discourage potential attackers through psychological means. Signs warning of prosecution don't physically prevent access (preventive) but discourage it by threatening consequences.

Critical Trap

Deterrent = Discourages through fear/psychology. Preventive = Physically blocks through mechanics.

Q24: Detective vs. Corrective Trap

Question

An IDS detects an intrusion and automatically blocks the malicious IP. Is this detective or corrective?

A. Detective only
B. Corrective only
C. Both detective and corrective
D. Preventive

Q24: Explanation

Correct Answer: C

The system performs **both** functions:

- **Detective:** It identifies the intrusion
- **Corrective:** It blocks the malicious IP (corrects the situation)

This is common in modern IDPS systems - they detect AND respond. The detection is detective; the blocking is corrective.

Critical Trap

Modern controls often combine multiple functions. IDS with auto-block = Detective + Corrective.

Q25: Compensating Control Limitations

Question

A compensating control is implemented because the primary control is not feasible. What must be TRUE for the compensating control to be acceptable?

- A It must be cheaper than the primary control
- B It must provide equivalent or superior risk reduction
- C It must be approved by the IT department
- D It must be automated

Q25: Explanation

Correct Answer: B

A compensating control must provide **equivalent or superior risk reduction** to the primary control. Cost is not the deciding factor - effectiveness is. The control must address the same risk at an acceptable level.

Critical Trap

Compensating control = Same risk reduction, different method. Cheaper but less effective = NOT acceptable.

Q26: Control Testing Frequency

Question

How often should controls be tested?

A. Annually for all controls

B. Based on risk criticality and regulatory requirements

C. Only when there is a change

D. Quarterly for all controls

Q26: Explanation

Correct Answer: B

Control testing frequency should be based on:

- **Risk criticality:** High-risk controls tested more frequently
- **Regulatory requirements:** Some regulations mandate specific frequencies
- **Control stability:** Stable controls may need less frequent testing
- **Change frequency:** Controls subject to change need more testing

Critical Trap

One size does NOT fit all. Risk-based frequency ¿ Fixed schedule.

Q27: Control Implementation Failure

Question

A control was implemented but is not operating as designed. This is an example of:

A. Control design deficiency
B. Control operating deficiency
C. Control gap
D. Control redundancy

Q27: Explanation

Correct Answer: B

Operating deficiency = Control is designed correctly but not operating effectively. **Design deficiency** = Control is not designed to address the risk. The distinction is critical for remediation.

Critical Trap

Design deficiency = Wrong control for the risk. Operating deficiency = Right control, not working.

Q28: Parallel Changeover Risk

Question

What is the PRIMARY risk of parallel changeover?

A. Data inconsistency between systems
B. Complete system failure
C. User resistance to change
D. Extended implementation timeline

Q28: Explanation

Correct Answer: A

Data inconsistency is the primary risk because:

- Both systems are processing transactions
- Data may be entered in one but not the other
- Synchronization failures can occur
- Reconciliation becomes complex

While parallel is the safest for availability, data consistency is the trade-off.

Critical Trap

Parallel = Safest for availability, riskiest for data consistency. Data reconciliation is critical.

Q29: Abrupt Changeover Appropriate When

Question

When is abrupt changeover acceptable?

A. When the system is critical to business operations
B. When the change is minor and rollback is easy
C. When users are well-trained
D. When the vendor recommends it

Q29: Explanation

Correct Answer: B

Abrupt changeover is only acceptable when:

- The change is **minor** (low risk)
- **Rollback is easy** (can revert quickly)
- **Business impact is minimal**
- No critical business processes are affected

Critical Trap

Abrupt = Fastest but highest risk. Only for non-critical, easily reversible changes.

Q30: Post-Implementation Review Timing

Question

When should a post-implementation review occur?

A. Immediately after go-live
B. After the system has been stable for a period
C. Only if there were issues
D. Before the next audit

Q30: Explanation

Correct Answer: B

The post-implementation review should occur **after the system has been stable for a period** (typically 3-6 months) to:

- Allow issues to surface
- Gather meaningful user feedback
- Assess actual performance vs. expected
- Identify lessons learned

Critical Trap

Too early = Issues haven't surfaced. Too late = Lessons forgotten. Wait for stability, then review.

Q31: KRI vs. KPI vs. KCI

Question

The percentage of employees who completed security awareness training is a:

A. Key Risk Indicator (KRI)
B. Key Performance Indicator (KPI)
C. Key Control Indicator (KCI)
D. None of the above

Q31: Explanation

Correct Answer: B

Training completion is a **KPI** because:

- It measures **performance** of the training program
- It looks **backward** at what has been accomplished
- It doesn't predict risk (that would be KRI)
- It doesn't measure control effectiveness directly (that would be KCI)

Critical Trap

Training completion = KPI (Performance). Phishing click rate = KRI (Risk predictor). Access review completion = KCI (Control effectiveness).

Q32: KRI Threshold Breach

Question

A KRI has a threshold of 10

A. Escalate to senior management

B. Investigate the cause of the breach

C. Implement additional controls

D. Update the risk register

Q32: Explanation

Correct Answer: B

Investigate first before taking action. The breach could be:

- A data quality issue (false alarm)
- A temporary spike (not a trend)
- A genuine risk increase requiring response

Understanding the cause determines the appropriate response.

Critical Trap

Threshold breach not equal to Immediate escalation. Investigate first, then respond appropriately.

Q33: Dashboard Audience

Question

Which report format is MOST appropriate for the Board of Directors?

A. Detailed technical vulnerability report
B. One-page executive summary with key metrics
C. Full risk register with all 500 risks
D. Raw SIEM logs

Q33: Explanation

Correct Answer: B

The Board needs **concise, business-focused information**:

- One page maximum
- Key metrics (KRIs/KPIs)
- Business impact, not technical details
- Trends and actionable insights
- Comparison to risk appetite

Critical Trap

Board not equal to Technical audience. Business language, not technical jargon.

Q34: SMART KRI Criteria

Question

A KRI is defined as "number of security incidents." What is the primary weakness of this KRI?

- A It is not measurable
- B It lacks specificity and thresholds
- C It is too difficult to track
- D It is not relevant to security

Q34: Explanation

Correct Answer: B

"Number of security incidents" lacks:

- **Specificity:** What type of incidents? What severity?
- **Thresholds:** What number triggers action?
- **Timeframe:** Per day? Per month? Trend?
- **Actionability:** What response is expected?

A good KRI: "Number of critical severity incidents per month exceeding threshold of 3."

Critical Trap

Vague KRI = Useless KRI. Specific + Measurable + Threshold + Actionable.

Q35: Control Monitoring Purpose

Question

The PRIMARY purpose of control monitoring is to:

A. Verify the control is working as designed
B. Verify the control is effectively reducing risk
C. Verify the control is cost-effective
D. Verify the control is automated

Q35: Explanation

Correct Answer: B

The primary purpose is to verify **risk reduction effectiveness**, not just operation. A control can be "working as designed" but not actually reducing risk if:

- The design is flawed
- The threat landscape has changed
- The control is redundant

Critical Trap

Control working not equal to Control effective. Monitor effectiveness, not just operation.

Q36: Heat Map Limitation

Question

What is the PRIMARY limitation of a risk heat map?

A. It is too complex for executives

B. It is qualitative and subjective

C. It cannot show multiple risks

D. It requires too much data

Q36: Explanation

Correct Answer: B

Heat maps are **qualitative and subjective**:

- "High" impact means different things to different people
- No quantification of actual loss
- Difficult to compare across business units
- Can oversimplify complex risks

Dashboards with quantitative metrics address this limitation.

Critical Trap

Heat map = Qualitative = Subjective. Dashboard = Quantitative + Qualitative = More objective.

Q37: Reporting Frequency

Question

How often should risk reports be provided to senior management?

A. Annually
B. Quarterly
C. Monthly
D. Based on risk velocity and organizational needs

Q37: Explanation

Correct Answer: D

Reporting frequency should be **risk-based**:

- **High-velocity risks:** More frequent (monthly/weekly)
- **Stable risks:** Less frequent (quarterly)
- **Regulatory requirements:** May mandate frequency
- **Organizational culture:** Some prefer more frequent updates

Critical Trap

One size does NOT fit all. Risk velocity determines reporting frequency.

Q38: Exception Reporting

Question

What should be included in an exception report to management?

A. Only the list of exceptions
B. Exceptions, compensating controls, risk owner, and expiration date
C. Only exceptions that exceed 1 year
D. Only exceptions approved by IT

Q38: Explanation

Correct Answer: B

Exception reports should include:

- **Description:** What is the exception?
- **Compensating controls:** How is risk being managed?
- **Risk owner:** Who accepted the risk?
- **Expiration date:** When must it be renewed?
- **Business justification:** Why is it needed?

Critical Trap

Exception report not equal to Simple list. Must include risk context and management details.

Q39: KCI vs. KRI

Question

The number of access reviews completed on time is a:

A. Key Risk Indicator (KRI)
B. Key Performance Indicator (KPI)
C. Key Control Indicator (KCI)
D. None of the above

Q39: Explanation

Correct Answer: C

Access reviews are a **control**. The percentage completed on time measures **control effectiveness** = KCI.

- KRI: Predicts risk (e.g., number of orphan accounts)
- KPI: Measures performance (e.g., time to complete reviews)
- KCI: Measures control effectiveness (e.g.,

Critical Trap

KCI = Control effectiveness. If it measures a control, it's a KCI.

Q40: Log Retention

Question

How long should security logs be retained?

A. 30 days

B. 90 days

C. Based on regulatory requirements and forensic needs

D. Indefinitely

Q40: Explanation

Correct Answer: C

Log retention should be based on:

- **Regulatory requirements:** Some industries mandate 1-7 years
- **Forensic needs:** Enough time to investigate incidents
- **Storage costs:** Balance cost vs. benefit
- **Legal hold requirements:** Litigation may require preservation

Critical Trap

No universal log retention period. Regulatory + Forensic + Legal = Retention period.

Q41: Risk Response Selection Trap

Question

A risk has been assessed as "High" (likelihood: 80

A. Accept the risk because mitigation cost is high

B. Mitigate because cost ($100K) ¡ risk exposure ($400K)

C. Transfer the risk through insurance

D. Avoid the risk entirely

Q41: Explanation

Correct Answer: B

Mitigation is justified:

- Expected loss = 80
- Control cost = $100K
- Net benefit = $300K
- Residual risk would be below appetite

Critical Trap

Expected loss = Likelihood × Impact. Mitigation justified when control cost ¡ expected loss.

Q42: Risk Owner Authority Trap

Question

A risk owner wants to accept a risk that exceeds the organization's risk appetite. They argue that their business unit has special circumstances. What should happen?

A. Allow the acceptance because they are the risk owner

B. Escalate to senior management for approval

C. Automatically transfer the risk

D. Automatically avoid the risk

Q42: Explanation

Correct Answer: B

Risk acceptance above the **enterprise risk appetite** requires **executive approval**. A business unit cannot unilaterally accept risk that exceeds organizational tolerance levels. This ensures:

- Enterprise-level perspective on risk
- Consistency in risk-taking across BUs
- Board oversight of significant risk

Critical Trap

Risk owner not equal to Unlimited authority. Exceeding risk appetite = Escalation required.

Q43: Third-Party Assessment Trap

Question

A vendor provides a SOC 2 Type II report with no exceptions. Can you rely on this for vendor security assessment?

A. Yes, SOC 2 Type II with no exceptions means the vendor is secure

B. Yes, if the scope matches your requirements

C. No, you must always conduct your own assessment

D. No, SOC 2 is not relevant for vendor assessment

Q43: Explanation

Correct Answer: B

It depends on scope. A SOC 2 Type II report is valuable IF:

- The scope covers the services you're using
- The Trust Services Criteria are relevant
- The period is recent (within 12 months)
- No exceptions or compensating controls are acceptable

You may still need supplemental assessment for gaps.

Critical Trap

SOC 2 = Useful, but check scope first. Wrong scope = Wrong assurance.

Q44: Control Monitoring Trap

Question

A control has been operating effectively for 3 years. Can the frequency of testing be reduced?

A. No, controls must always be tested annually

B. Yes, if the control environment is stable and risk is low

C. No, regulatory requirements mandate annual testing

D. Yes, after 3 years of effective operation, testing can stop

Q44: Explanation

Correct Answer: B

Testing frequency can be **reduced** if:

- Control has a strong track record (3 years effective)
- The control environment is stable
- Risk is low/stable
- No significant changes to the process
- Regulatory requirements allow it

However, monitoring should never stop completely.

Critical Trap

Strong track record = Reduced testing, NOT no testing. Risk-based frequency adjustments are acceptable.

Q45: Risk Acceptance Trap

Question

A CEO verbally accepts a high risk without documentation. Is this valid risk acceptance?

A. Yes, CEO has ultimate authority
B. No, risk acceptance must be documented
C. Yes, if the CEO communicates it to the board
D. No, only the board can accept risk

Q45: Explanation

Correct Answer: B

Risk acceptance must be **formally documented** and include:

- Risk description and impact
- Rationale for acceptance
- Risk owner signature
- Duration of acceptance
- Review schedule

Verbal acceptance provides no audit trail and is not defensible.

Critical Trap

Verbal acceptance = No accountability. Documentation is mandatory.

Q46: Control Implementation Trap

Question

A control has been designed and implemented. What must happen before it can be considered effective?

A. The vendor must certify it
B. It must be tested and verified
C. It must be approved by the board
D. It must be automated

Q46: Explanation

Correct Answer: B

A control is not effective until it has been **tested and verified**.
Implementation not equal to Effectiveness. Testing confirms:

- The control operates as designed
- The control actually reduces risk
- There are no gaps or weaknesses
- The control is sustainable

Critical Trap

Implementation not equal to Effectiveness. Testing is required to confirm effectiveness.

Q47: KRI Maintenance Trap

Question

Why must KRIs be maintained and updated regularly?

A. To keep them complex and sophisticated

B. Because threats and vulnerabilities change over time

C. To justify the risk management budget

D. To satisfy audit requirements

Q47: Explanation

Correct Answer: B

KRIs must evolve because the **risk environment changes**:

- New threats emerge
- Vulnerabilities are discovered/patch
- Business objectives change
- Regulatory requirements evolve
- Technology landscape shifts

Stale KRIs provide false assurance.

Critical Trap

KRIs are NOT set-and-forget. Regular review and update is required.

Q48: Risk Reporting Trap

Question

A risk report shows all risks are "green" (low). What should the risk manager do?

A. Celebrate - the organization is secure

B. Investigate whether the assessment is accurate or overly optimistic

C. Reduce the risk management budget

D. Focus on other priorities

Q48: Explanation

Correct Answer: B

All "green" is a **red flag**. It could indicate:

- Risk assessment is too lenient
- Risks are not being identified
- Thresholds are set too high
- The organization is in denial
- Complacency has set in

A healthy risk portfolio usually has some amber/red items.

Critical Trap

All green = Suspicious. Investigate, don't celebrate.

Q49: Control Testing Trap

Question

A control test reveals one exception out of 100 samples. What should the risk manager conclude?

A. The control is effective (99
B. The control has a deficiency that requires investigation
C. The exception should be ignored (statistical anomaly)
D. The control should be immediately replaced

Q49: Explanation

Correct Answer: B

Any exception requires **investigation**:

- What caused the exception?
- Is it a design flaw or operating issue?
- Is it an isolated event or systemic?
- Are compensating controls in place?

Even 1

Critical Trap

Any exception = Investigate. Don't dismiss as statistical anomaly.

Q50: Risk Treatment Trap

Question

A risk has been mitigated to within risk appetite. What is the NEXT step?

A. Close the risk and stop monitoring

B. Continue monitoring to ensure risk remains within appetite

C. Transfer the remaining risk

D. Accept the residual risk

Q50: Explanation

Correct Answer: B

After mitigation, **continuous monitoring** is required because:

- Risk levels can change over time
- Controls can degrade or fail
- New threats may emerge
- Business changes may alter risk profile

Residual risk is not static.

Critical Trap

Mitigated not equal to Forgotten. Continuous monitoring is essential.

Q51: Risk Appetite vs. Tolerance Trap

Question

The risk appetite is $100K. The risk tolerance is $150K. A risk is currently at $120K. What does this mean?

A. The risk is within appetite
B. The risk exceeds appetite but is within tolerance
C. The risk exceeds both appetite and tolerance
D. The risk is within tolerance but exceeds capacity

Q51: Explanation

Correct Answer: B

Risk appetite = $100K (desired level)
Risk tolerance = $150K (acceptable deviation)
Current risk = $120K
The risk is:

- Above appetite ($120K ¿ $100K) - requires attention
- Within tolerance ($120K ¡ $150K) - acceptable with monitoring

Critical Trap

Appetite = Target. Tolerance = Acceptable range. Between them = Monitor closely.

Q52: Risk Capacity Trap

Question

The risk capacity is $500K. A risk is at $450K. What is the recommended action?

A. No action needed - within capacity
B. Immediate action to reduce risk below appetite
C. Escalate to senior management and reduce risk urgently
D. Transfer the risk immediately

Q52: Explanation

Correct Answer: C

Approaching **risk capacity** ($450K vs. $500K) is a **critical situation**:

- Capacity = maximum risk before existence is threatened
- Being at 90
- Any additional risk could threaten the organization
- Immediate escalation and action required

Critical Trap

Approaching capacity = Emergency. Capacity breach = Existential threat.

Q53: Inherent vs. Residual Trap

Question

A risk has an inherent risk of $1M. Controls costing $200K reduce this to $300K. What is the residual risk?

A. $1M
B. $300K
C. $500K
D. $800K

Q53: Explanation

Correct Answer: B

Residual risk = $300K (the risk remaining after controls). The calculation:

- Inherent risk = $1M
- Control cost = $200K (not subtracted from risk)
- Residual risk = $300K (risk after controls)

Control cost is a separate consideration (cost-benefit analysis), not a risk reduction.

Critical Trap

Residual risk = Risk after controls, NOT risk minus control cost.

Q54: Control Cost Trap

Question

A control costs $100K and reduces risk from $500K to $100K. What is the ROI of the control?

A. 100
B. 300
C. 400
D. Cannot be determined

Q54: Explanation

Correct Answer: B

ROI = 300%

- Risk reduction = $500K - $100K = $400K
- Control cost = $100K
- Net benefit = $400K - $100K = $300K
- ROI = Net benefit / Control cost = $300K / $100K = 300%

Critical Trap

ROI = (Risk Reduction - Control Cost) / Control Cost. Not just risk reduction / control cost.

Q55: Detection vs. Prevention Trap

Question

An organization installs motion detectors. What type of control is this?

A. Preventive
B. Detective
C. Deterrent
D. Corrective

Q55: Explanation

Correct Answer: B

Motion detectors are **detective** controls:

- They detect movement (intrusion)
- They do NOT prevent entry
- They alert to the presence of an intruder
- Detection triggers response (corrective)

They may have a deterrent effect, but their primary function is detection.

Critical Trap

Motion detector = Detective. It detects, it doesn't prevent.

Q56: Risk Acceptance Authority Trap

Question

Who has the authority to accept a risk that exceeds the enterprise risk appetite?

A. Risk owner

B. Control owner

C. Board of directors or equivalent

D. IT manager

Q56: Explanation

Correct Answer: C

Risk acceptance **above enterprise risk appetite** requires **board-level approval** because:

- It affects the entire organization
- It may impact shareholder value
- It requires strategic perspective
- It may have regulatory implications

Critical Trap

Board sets risk appetite. Board approves exceptions to appetite.

Q57: Control Design Trap

Question

A control is designed to prevent unauthorized access. However, it is too complex for users, so they bypass it. What type of deficiency is this?

A. Operating deficiency
B. Design deficiency
C. Both design and operating deficiency
D. No deficiency

Q57: Explanation

Correct Answer: B

This is a **design deficiency** because:

- The control was designed poorly (too complex)
- User bypass is a predictable consequence
- The design failed to consider usability
- A better design would balance security and usability

The control doesn't work because of how it was designed.

Critical Trap

Design flaw causes operating failure. Root cause = Design deficiency.

Q58: Risk Register Trap

Question

What is the MOST important element of a risk register entry?

A. Risk description
B. Risk owner
C. Risk score
D. Mitigation plan

Q58: Explanation

Correct Answer: B

Risk owner is most important because:

- Without an owner, no one is accountable
- Other elements (description, score, plan) are useless without ownership
- Owner drives the risk management process
- Owner ensures the risk is monitored and addressed

Critical Trap

No owner = No accountability = No risk management. Owner is the foundation.

Q59: Third-Party Risk Trap

Question

A vendor has a SOC 2 Type II report with no exceptions. Your company uses the vendor for a service NOT covered in the SOC 2 scope. What should you do?

- A Rely on the SOC 2 report anyway
- B Conduct additional assessment for the out-of-scope service
- C Reject the vendor entirely
- D Request a new SOC 2 report

Q59: Explanation

Correct Answer: B

The SOC 2 report only covers the **scope defined in the report**. If your service is out of scope, you must:

- Conduct your own assessment of that service
- Request a scope expansion from the vendor
- Implement additional controls
- Document the gap and residual risk

Critical Trap

SOC 2 scope not equal to All services. Out of scope = Additional assessment required.

Q60: Risk Response Documentation Trap

Question

Why must risk responses be documented?

A. To satisfy auditors

B. To provide evidence of due care and accountability

C. To justify budget requests

D. To track project progress

Q60: Explanation

Correct Answer: B

Documentation provides **evidence of due care**:

- Shows the organization took risk seriously
- Demonstrates accountability
- Protects against negligence claims
- Provides audit trail for decisions
- Enables continuous improvement

Critical Trap

Undocumented = Undefensible. Documentation = Due care evidence.

Q61: Risk Velocity Trap

Question

What is risk velocity and why does it matter?

A. Speed at which risk is identified
B. Speed at which risk materializes
C. Speed at which controls are implemented
D. Speed at which risk is reported

Q61: Explanation

Correct Answer: B

Risk velocity = speed at which risk materializes. It matters because:

- High-velocity risks require faster response
- Affects monitoring frequency (higher velocity = more frequent)
- Impacts risk appetite (high velocity = lower tolerance)
- Determines urgency of mitigation

Critical Trap

High velocity = Less time to react. Velocity determines response urgency.

Q62: Key Risk Indicator Trap

Question

A KRI is showing a consistent upward trend but is still below threshold. What should the risk manager do?

A. No action needed - below threshold

B. Investigate the trend and prepare for potential threshold breach

C. Wait for the threshold to be breached

D. Report to the board immediately

Q62: Explanation

Correct Answer: B

Trend analysis is critical:

- Upward trend indicates increasing risk
- Threshold may be breached soon
- Preventive action can be taken now
- Understanding the cause enables proactive response

Critical Trap

Below threshold not equal to No action. Trend is as important as current value.

Q63: Control Monitoring Trap

Question

A control has been automated. Does this eliminate the need for monitoring?

A. Yes, automated controls are self-monitoring

B. No, automated controls can fail and must be monitored

C. Yes, automation eliminates human error

D. No, but monitoring frequency can be reduced

Q63: Explanation

Correct Answer: B

Automated controls **still require monitoring**:

- Automation can fail (bugs, configuration errors)
- Automated controls can be bypassed
- The automation logic may become outdated
- Regular testing confirms continued effectiveness

Critical Trap

Automated not equal Self-monitoring. Automation reduces human error but doesn't eliminate need for oversight.

Q64: Risk Acceptance Documentation Trap

Question

A risk acceptance was documented but not periodically reviewed. What is the consequence?

A. No consequence - documentation exists

B. The risk may have changed; old acceptance may not be valid

C. The risk is automatically transferred

D. The risk is automatically avoided

Q64: Explanation

Correct Answer: B

Without periodic review:

- The risk may have increased
- The business context may have changed
- New controls may make acceptance unnecessary
- The acceptance may have expired

Regular review ensures the acceptance remains valid and appropriate.

Critical Trap

Old acceptance = Potentially invalid. Annual review is mandatory.

Q65: Control Testing Approach Trap

Question

When testing a control, what is the BEST approach?

A. Test every transaction

B. Use statistical sampling and document methodology

C. Test only the most recent transactions

D. Rely on management's assurance

Q65: Explanation

Correct Answer: B

Statistical sampling is best because:

- Testing every transaction is impractical
- Proper sampling provides reasonable assurance
- Documented methodology enables repeatability
- Results can be defended to auditors

Critical Trap

Testing = Sampling (not 100Document methodology for auditability.

Q66: Risk Response Cost Trap

Question

The cost of a control is $50K. The expected loss without the control is $40K. What is the BEST response?

A. Implement the control - $50K is affordable
B. Accept the risk - control cost exceeds expected loss
C. Transfer the risk - cheaper than implementing
D. Avoid the risk - too expensive to mitigate

Q66: Explanation

Correct Answer: B

When **control cost ¿ expected loss**, accept the risk:

- Control cost = $50K
- Expected loss = $40K
- Spending $50K to prevent $40K loss is not justified
- Accept the risk (with documentation)

Unless there are regulatory or strategic reasons to implement.

Critical Trap

Control cost ¿ Expected loss = Accept. Economic analysis is fundamental.

Q67: Reporting to Board Trap

Question

What should NOT be included in a board-level risk report?

- A Key risk indicators and trends
- B Comparison to risk appetite
- C Technical details of vulnerabilities
- D Recommended actions

Q67: Explanation

Correct Answer: C

Technical details should NOT be in board reports:

- Board members are not technical experts
- Focus should be on business impact
- Technical details obscure the message
- Board needs strategic view, not operational

Critical Trap

Board = Business language. Technical details = Operational reports.

Q68: Risk Monitoring Trap

Question

What is the PRIMARY purpose of continuous risk monitoring?

A. To satisfy audit requirements

B. To detect changes in risk profile in real-time

C. To justify the risk management budget

D. To track project progress

Q68: Explanation

Correct Answer: B

Continuous monitoring enables **real-time awareness** of:

- Changes in risk levels
- New threats emerging
- Control failures
- Risk appetite breaches

This enables proactive rather than reactive risk management.

Critical Trap

Continuous monitoring = Real-time awareness. Not just for audit - for proactive management.

Q69: Key Control Indicator Trap

Question

The percentage of firewall rules reviewed and approved is a:

A. Key Risk Indicator (KRI)
B. Key Performance Indicator (KPI)
C. Key Control Indicator (KCI)
D. None of the above

Q69: Explanation

Correct Answer: C

This is a **KCI** because:

- Firewall rule review is a **control**
- The metric measures **control effectiveness**
- It doesn't predict risk (KRI)
- It doesn't measure overall performance (KPI)

Critical Trap

If it measures a control = KCI. If it predicts risk = KRI. If it measures performance = KPI.

Q70: Risk Owner Trap

Question

The risk owner for a data breach risk is the CIO. Is this appropriate?

A. No, the CISO should own all security risks
B. Yes, if the breach impacts IT objectives
C. No, only the CEO can own this risk
D. No, the board should own this risk

Q70: Explanation

Correct Answer: B

The risk owner should be the person who **owns the objective at risk**:

- If the breach impacts IT objectives (availability, integrity), CIO is appropriate
- If it impacts business objectives (customer trust, revenue), business leader is appropriate
- Risk ownership follows accountability for objectives

Critical Trap

Risk owner = Objective owner. Not necessarily IT, not necessarily security.

Q71: Exception Management Trap

Question

An exception has been open for 3 years. What is the BEST action?

A. Renew for another year

B. Review to determine if it is still needed and valid

C. Automatically close it

D. Escalate to the board

Q71: Explanation

Correct Answer: B

Long-standing exceptions require **detailed review**:

- Is the original justification still valid?
- Have conditions changed?
- Can the exception be closed?
- Are compensating controls still adequate?

Exceptions should not be auto-renewed indefinitely.

Q72: Control Owner Trap

Question

A control owner leaves the organization. What should happen to the control?

A. The control is no longer needed
B. The control continues without an owner
C. A new owner should be assigned immediately
D. The control should be retired

Q72: Explanation

Correct Answer: C

A **new control owner must be assigned immediately**:

- Controls without owners become orphaned
- No one monitors effectiveness
- No one maintains the control
- Control degradation is likely

Q73: Risk Response Trap

Question

A risk has been mitigated. The residual risk is within appetite. The risk owner wants to close the risk. What should the risk manager say?

A. Yes, close it - within appetite

B. No, continue monitoring to ensure it stays within appetite

C. No, always retain the risk in the register

D. Yes, but only after board approval

Q73: Explanation

Correct Answer: B

The risk should **remain monitored**:

- Risk conditions can change
- Controls can degrade
- New threats can emerge
- Continuous monitoring confirms continued acceptability

The risk can be downgraded but not fully closed.

Q74: Third-Party Risk Trap

Question

A vendor's security posture has deteriorated since onboarding. What is the FIRST action?

A. Terminate the contract immediately

B. Assess the impact on your organization and communicate with the vendor

C. Transfer the risk to another vendor

D. Accept the risk and monitor

Q74: Explanation

Correct Answer: B

Assess and communicate first:

- Understand what has changed
- Determine impact on your data
- Communicate concerns to the vendor
- Develop a remediation plan
- Only terminate if necessary

Q75: KRI Threshold Trap

Question

A KRI has breached its threshold. What should the risk manager do FIRST?

A. Implement additional controls

B. Escalate to senior management

C. Investigate the cause of the breach

D. Update the risk register

Q75: Explanation

Correct Answer: C

Investigate first before taking action:

- Is the data accurate?
- Is it a temporary spike or a trend?
- What is the root cause?
- What is the appropriate response?

Understanding the cause determines the right action.

Q76: Control Effectiveness Trap

Question

A control has been tested and found effective. How long is this assurance valid?

- A Indefinitely
- B 1 year
- C Until conditions change or next test
- D 3 years

Q76: Explanation

Correct Answer: C

Control effectiveness assurance is **point-in-time**:

- Valid until conditions change
- New threats can emerge
- Controls can degrade
- Personnel changes can affect operation

Regular retesting is required.

Q77: Risk Appetite Trap

Question

Who is responsible for defining the organization's risk appetite?

A. Risk manager
B. CISO
C. Board of directors
D. IT manager

Q77: Explanation

Correct Answer: C

The **Board of Directors** defines risk appetite:

- It represents stakeholder interests
- It has strategic oversight
- It sets the tone for the organization
- It has authority to accept enterprise risk

Q78: Risk Monitoring Trap

Question

What should trigger a review of the risk register?

A. Annual audit

B. Only when a risk materializes

C. Any significant change in environment, threats, or business

D. Monthly

Q78: Explanation

Correct Answer: C

The risk register should be reviewed when:

- New threats emerge
- Business objectives change
- New regulations are introduced
- Significant incidents occur
- Organizational changes happen

Q79: Control Testing Trap

Question

What is the difference between a control test and a control assessment?

A. No difference
B. Test is for IT, assessment is for business
C. Test verifies operation, assessment evaluates overall effectiveness
D. Test is quantitative, assessment is qualitative

Q79: Explanation

Correct Answer: C

- **Control test:** Verifies the control is operating as designed (specific procedure)
- **Control assessment:** Evaluates whether the control is effectively reducing risk (overall judgment)

Testing is a component of assessment.

Q80: Risk Response Trap

Question

A risk has been transferred. Does the organization still need to monitor it?

A. No, transfer eliminates responsibility

B. Yes, transfer does not eliminate accountability

C. No, the third party is responsible

D. Only if required by contract

Q80: Explanation

Correct Answer: B

Transfer does not eliminate accountability:

- You remain accountable to regulators
- Reputational risk remains
- The third party may fail
- You must monitor the third party's performance

Q81: Risk Reporting Trap

Question

What is the MOST important quality of a risk report?

A. Comprehensiveness
B. Actionability
C. Technical accuracy
D. Visual appeal

Q81: Explanation

Correct Answer: B

Actionability is most important:

- Reports should enable decisions
- Without action, reporting is pointless
- Readers should know what to do
- Focus on insights, not data

Q82: Risk Culture Trap

Question

What is the STRONGEST indicator of a healthy risk culture?

A. No security incidents
B. Employees report risks without fear
C. All risks are within appetite
D. Zero audit findings

Q82: Explanation

Correct Answer: B

Open risk reporting indicates healthy culture:

- No fear of blame
- Proactive risk identification
- Learning from mistakes
- Continuous improvement

Q83: Control Category Trap

Question

A policy requiring password complexity is what type of control?

A. Technical
B. Administrative
C. Physical
D. Detective

Q83: Explanation

Correct Answer: B

Password policy is an **administrative control**:

- It is a policy document
- It defines requirements
- It is not technical (enforced by technology)
- It is not physical

Q84: Risk Acceptance Trap

Question

What should be included in a risk acceptance document?

A. Only the risk description
B. Risk description, justification, owner, and review date
C. Only the approval signature
D. Only the mitigation plan

Q84: Explanation

Correct Answer: B

Risk acceptance should include:

- Risk description and impact
- Business justification
- Risk owner (who accepts)
- Duration and review date
- Compensating controls

Q85: Third-Party Trap

Question

When should a vendor risk assessment be updated?

A. Only at contract renewal

B. Annually or when significant changes occur

C. Every 3 years

D. Only when there is a breach

Q85: Explanation

Correct Answer: B

Vendor assessments should be updated:

- **Annually** (minimum)
- When the vendor's services change
- When there is a vendor incident
- When regulations change
- When the vendor's security posture changes

Q86: Risk Monitoring Trap

Question

What is the purpose of a risk dashboard?

A. To show all risks in detail

B. To provide a consolidated view of key risk indicators

C. To replace the risk register

D. To satisfy audit requirements

Q86: Explanation

Correct Answer: B

A dashboard provides **consolidated view**:

- Key metrics at a glance
- Trend identification
- Comparison to thresholds
- Executive-level visibility

Q87: Control Testing Trap

Question

What should be done if a control test reveals a design deficiency?

A. Ignore it - testing is complete

B. Document and recommend redesign

C. Implement a compensating control only

D. Accept the risk

Q87: Explanation

Correct Answer: B

Design deficiencies require **redesign**:

- Document the finding
- Assess the impact
- Recommend redesign
- Implement compensating controls temporarily
- Retest after redesign

Q88: Risk Appetite Trap

Question

How often should risk appetite be reviewed?

A. Never - it should remain constant

B. Annually or when significant changes occur

C. Every 5 years

D. Only when there is a breach

Q88: Explanation

Correct Answer: B

Risk appetite should be reviewed:

- **Annually** (minimum)
- When business strategy changes
- When market conditions change
- When there are significant incidents

Q89: Risk Response Trap

Question

What is the PRIMARY consideration when selecting a risk response?

A. Cost of the response
B. Alignment with business objectives and risk appetite
C. Ease of implementation
D. Vendor recommendations

Q89: Explanation

Correct Answer: B

Alignment with business objectives is primary:

- Risk response should support business goals
- Should bring risk within appetite
- Cost is secondary to effectiveness
- Ease of implementation is operational

Q90: Risk Register Trap

Question

How often should a risk register be updated?

A. Annually

B. When risks change or new risks emerge

C. Quarterly

D. Monthly

Q90: Explanation

Correct Answer: B

The risk register should be updated **when conditions change**:

- New risks identified
- Risk levels change
- Risk responses implemented
- Risk owners change

It is a living document, not a periodic report.

Q91: Exception Trap

Question

Who should approve a policy exception?

A. IT manager

B. Business process owner or delegate with authority

C. Risk manager

D. Anyone affected by the policy

Q91: Explanation

Correct Answer: B

Exceptions should be approved by the **business process owner**:

- They own the risk
- They have budget authority
- They understand the business need
- They are accountable for the exception

Q92: Risk Monitoring Trap

Question

What is the difference between monitoring and auditing?

A. No difference
B. Monitoring is continuous, auditing is periodic
C. Monitoring is internal, auditing is external
D. Monitoring is automated, auditing is manual

Q92: Explanation

Correct Answer: B

- **Monitoring:** Continuous, ongoing oversight
- **Auditing:** Periodic, independent examination

Monitoring is the day-to-day function; auditing provides independent assurance.

Q93: Control Design Trap

Question

What should be considered FIRST when designing a control?

A. Cost of the control
B. Risk being addressed
C. Available technology
D. User convenience

Q93: Explanation

Correct Answer: B

The **risk being addressed** is primary:

- Understand the risk first
- Then design appropriate control
- Cost is secondary
- Technology is a means, not the end

Q94: KRI Selection Trap

Question

What makes a KRI effective?

A. It is easy to measure

B. It is actionable and predictive of risk

C. It is approved by the board

D. It is automated

Q94: Explanation

Correct Answer: B

Effective KRIs are **actionable and predictive**:

- They predict future risk
- They trigger action when breached
- They are relevant to the risk
- They enable proactive management

Q95: Risk Response Trap

Question

What is residual risk?

A. Risk before controls
B. Risk after controls
C. Risk that is accepted
D. Risk that is transferred

Q95: Explanation

Correct Answer: B

Residual risk = risk after controls:

- Inherent risk - Control effectiveness = Residual risk
- It is the risk that remains
- It must be within risk appetite
- It must be accepted by management

Q96: Control Implementation Trap

Question

What is the FIRST step in implementing a control?

A. Purchase the technology

B. Define the control objective and requirements

C. Train the users

D. Test the control

Q96: Explanation

Correct Answer: B

Define objectives first:

- What risk are we addressing?
- What should the control achieve?
- What are the requirements?
- Then select and implement the solution

Q97: Risk Reporting Trap

Question

What is the BEST format for reporting to the board?

A. Detailed technical report

B. Executive summary with key metrics and recommendations

C. Full risk register

D. Raw data and logs

Q97: Explanation

Correct Answer: B

Board reports should be **concise and strategic**:

- Executive summary (1-2 pages)
- Key metrics and trends
- Comparison to appetite
- Recommended actions

Q98: Risk Acceptance Trap

Question

What happens if a risk is accepted without documentation?

A. Nothing - the risk is accepted

B. The acceptance may not be valid or defensible

C. The risk is automatically transferred

D. The risk is automatically avoided

Q98: Explanation

Correct Answer: B

Undocumented acceptance is **not defensible**:

- No evidence of due care
- Cannot prove informed decision
- May be considered negligence
- Vulnerable to legal challenge

Q99: Risk Monitoring Trap

Question

What should be monitored for third-party risks?

A. Only contract compliance
B. Security posture, incidents, and compliance
C. Only financial stability
D. Only service level agreements

Q99: Explanation

Correct Answer: B

Comprehensive third-party monitoring includes:

- Security posture (SOC reports, assessments)
- Incidents and breaches
- Regulatory compliance
- Financial stability
- Service level performance

Q100: Final Trap

Question

What is the ULTIMATE goal of risk response and reporting?

A. Eliminate all risk
B. Optimize risk to support business objectives
C. Satisfy auditors
D. Reduce insurance premiums

Q100: Explanation

Correct Answer: B

The ultimate goal is **risk optimization**:

- Risk cannot be eliminated
- Risk should be managed to acceptable levels
- Risk management enables business objectives
- Balance risk and reward

Final Wisdom

Risk management is not about eliminating risk.
It is about understanding risk and making informed decisions.

Final Summary

Key Takeaways for Domain C

- **Mitigate** = Reduce risk, not eliminate
- **Accept** = Formal, documented decision
- **Transfer** = Financial shift, accountability remains
- **Avoid** = Eliminate activity that creates risk
- **Risk Owner** = Business leader accountable for risk
- **Control Owner** = Implementer of controls
- **KRI** = Predicts risk (forward-looking)
- **KPI** = Measures performance (backward-looking)
- **KCI** = Measures control effectiveness

Good Luck on Your CRISC Exam!

Remember: The ISACA mindset is about understanding why a question is asked, not just what is technically correct.